Technische beschrijving en beveiligingsmaatregelen

Technische en organisatorische maatregelen (TOMs) conform artikel 32 AVG · bijlage bij de verwerkersovereenkomst · versie 1.1, 14 november 2026

Reikwijdte en stand van zaken. Deze beschrijving geldt voor een kantooromgeving van Scanstraat: een eigen server per kantoor, ingericht na een getekende verwerkersovereenkomst. Scanstraat heeft zelf geen ISO-, SOC- of ander certificaat. De certificaten in paragraaf 3 zijn van de subverwerkers en gaan over hun datacenters en diensten, niet over de software of werkwijze van Scanstraat. De openbare demonstratie op descanstraat.nl bevat alleen fictieve gegevens en valt buiten deze beschrijving.

1. De verwerking in het kort

Doel	Binnengekomen stukken splitsen, lezen en controleren, klaarzetten voor het boekhoud- en archiefpakket van het Kantoor, en conceptberichten aan klanten over ontbrekende stukken opstellen. Scanstraat boekt niets, dient niets in en verstuurt niets zonder goedkeuring van een medewerker van het Kantoor.
Gegevens	Naam-, adres- en contactgegevens, IBAN, factuur- en bongegevens, btw- en KvK-nummers, mogelijk een BSN op post van de Belastingdienst; gebruikers- en auditgegevens van medewerkers. Bijzondere gegevens zijn niet de bedoeling; zie maatregel M5.
Bewaren	Origineel, paginabeelden en koppeltabel van de pseudonimisering: gewist zodra het Kantoor de export heeft bevestigd. Uit de stapel gehaalde stukken: na 24 uur. Gecontroleerde velden en auditlog: zolang de overeenkomst loopt. Versleutelde back-ups: 7 dagen.

2. Maatregelen

Maatregel	Hoe het werkt (bestand in de code)
M1 Locatie	Server en back-ups bij Hetzner Online GmbH in Falkenstein of Neurenberg (Duitsland). Met een productie-instelling start de software alleen als hosting- en back-uplocatie een van die twee is (region.py). De software kan de fysieke plek niet zelf zien: het inrichtingsscript zet de server daar neer.
M2 Versleuteling in rust	Alle bestanden (scans, paginabeelden, pdf's, velden, koppeltabellen, gebruikers met hun 2FA-sleutels, berichten, auditlog) met AES-256-GCM; de sleutel staat buiten de datamap (vault.py). Back-ups apart versleuteld met een eigen sleutel (backup.py).
M3 Versleuteling onderweg	Alle verbindingen via HTTPS: minimaal TLS 1.2, TLS 1.3 waar de browser dat ondersteunt. Sessiecookies HttpOnly, SameSite=Lax en Secure; HSTS. Elk formulier en elke wijzigende aanroep met een CSRF-token.
M4 Toegang	Persoonlijke accounts, rollen beheerder en medewerker, wachtwoord plus verplichte tweestapsverificatie (TOTP). Na 5 foute pogingen 15 minuten blokkering. Een 2FA-code werkt maar één keer. Eerste inlog dwingt een nieuw wachtwoord af (auth.py).
M5 Minimale gegevens naar AI	Tekst wordt op de eigen server herkend. IBAN, e-mail, telefoon, BSN (met 11-proef) en geboortedatum worden met vaste regels vervangen, namen en woonadressen door een lokaal taalmodel (Apache 2.0). Wijst een stuk op gezondheid, vakbond, religie, politiek of strafrecht (AVG art. 9 en 10), dan blijft het hele stuk lokaal (privacy.py).
M6 Poort naar buiten	Eén module mag met een externe AI-dienst praten (egress.py). Die controleert vlak voor verzending opnieuw, los van het filter, en blokkeert bij elke gevonden persoonsgegeven of aanwijzing voor bijzondere gegevens. Alleen tekst: paginabeelden verlaten een productieserver nooit. Amazon Bedrock alleen in een EU-regio; een andere regio weigert de software.
M7 Keuze per kantoor	Stand lokaal: er gaat niets naar een AI-dienst. Stand hybride: alleen gefilterde tekst naar Claude via Amazon Bedrock, regio eu-west-1 (Ierland).
M8 Geen AI-beslissingen over geld	Btw per tarief, totalen, IBAN-controlegetal, IBAN tegenover eerdere facturen van dezelfde leverancier en de EN 16931-rekenregels op elk exportbestand zijn vaste code (checks.py, ubl.py). Het taalmodel doet alleen voorstellen.
M9 Menselijke goedkeuring	Geen export naar een pakket en geen bericht naar een klant zonder akkoord van een medewerker. Per klant een Wwft-stop. Dit is geen instelling en niet uit te zetten.
M10 Vastleggen	Auditlog van elke handeling (wie, wat, wanneer). Elke poging tot verzending naar de AI-dienst, verstuurd of geblokkeerd, met bestemming en een SHA-256-vingerafdruk van precies wat er wegging.
M11 Wissen	Automatisch volgens de bewaartermijnen hierboven: direct na bevestiging en als vangnet elke 5 minuten (retention.py). Na het einde van de overeenkomst alles binnen 30 dagen, back-ups 7 dagen later.
M12 Onderhoud en organisatie	Beveiligingsupdates maandelijks, kritieke updates binnen 72 uur. Geheimhouding. Datalek binnen 24 uur gemeld aan het Kantoor. Deze maatregelen worden jaarlijks herzien.

3. Subverwerkers en hun certificaten

Partij	Rol	Certificaten (van de partij zelf)	Afspraak
Hetzner Online GmbH, Duitsland	Server en versleutelde back-ups, Falkenstein of Neurenberg.	ISO/IEC 27001:2022, gecertificeerd door SOCOTEC Certification. Bereik: infrastructuur, beheer en support van de datacenterparken Neurenberg, Falkenstein en Helsinki. Geen SOC 2 of BSI C5 vermeld.	Verwerkersovereenkomst art. 28 AVG via het Hetzner-klantaccount.
Amazon Web Services EMEA SARL, Luxemburg (Amazon Bedrock)	Voert Claude (Anthropic) uit op gefilterde tekst. Alleen in de stand hybride. Regio eu-west-1.	ISO/IEC 27001:2022, 27017, 27018, 27701; SOC 1, 2 en 3; BSI C5. Amazon Bedrock staat op de AWS-lijsten van diensten binnen het bereik (Bedrock Marketplace uitgezonderd).	AWS-verwerkersvoorwaarden met standaardcontractbepalingen. Invoer en uitvoer niet gebruikt voor training.

Bronnen, nagekeken op 14 november 2026: hetzner.com/unternehmen/zertifizierung; aws.amazon.com/compliance/iso-certified; aws.amazon.com/compliance/services-in-scope/SOC; aws.amazon.com/compliance/services-in-scope/C5.
Geen subverwerker van Scanstraat, wel van het Kantoor zelf: het WhatsApp Business-account en de mailserver van het Kantoor en het boekhoudpakket (zoals SnelStart of Exact Online).

4. Grenzen en bewijs

Wat nog niet is gedaan. Er is nog geen externe penetratietest uitgevoerd. De leeskwaliteit van de lokale stand is nog niet gemeten op echte stukken; dat gebeurt in de proef op facturen van het Kantoor zelf. Geen filter is foutloos: daarom zijn er twee lagen (M5 en M6) en blijft een twijfelgeval lokaal.

Bewijs zonder klantdata. 1. In de browsertest op descanstraat.nl leest de browser een pdf-factuur; er wordt niets geüpload. 2. Het Kantoor doet hetzelfde met vijf eigen inkoopfacturen (internet, huur, kantoorartikelen) en leest het SI-UBL-bestand in een testadministratie van het eigen pakket in; ook dan verlaat er niets de computer van het Kantoor. 3. Pas daarna tekenen partijen de verwerkersovereenkomst en gaan drie klantdossiers door de volledige straat op de server van het Kantoor.

Scanstraat bereidt voor: er wordt niets ingediend of definitief geboekt zonder een medewerker van het Kantoor. Geen fiscaal of juridisch advies. Vragen over deze maatregelen of een controle volgens artikel 10 van de verwerkersovereenkomst: neem contact op via descanstraat.nl. De werking van het privacyfilter is live te zien op descanstraat.nl/veiligheid.